

NARRATIVA EXPLICATIVA: FUNDAMENTOS TEÓRICOS Y CONTEXTO

Encuesta Integral de Evaluación de Ciberseguridad

Versión: 2.0 | **Fecha:** Enero 2026 | **Audiencia:** Ejecutivos, Auditores, Consultores

Lectura: 15-20 minutos

INTRODUCCIÓN: ¿POR QUÉ ESTA ENCUESTA?

En el panorama actual de ciberseguridad española (2026), las organizaciones enfrentan un dilema:
¿Cómo sabemos si estamos seguros?

Existen metodologías de referencia (MAGERIT, NIST, ISO 27001), pero son fragmentadas y a menudo se aplican sin conexión clara con:

- Indicadores cuantitativos de riesgo (FAIR/ALE)
- Impacto financiero real
- Cumplimiento regulatorio integral (NIS2 + ENS)
- Métricas operacionales de madurez (CMM L0-L5)

Esta encuesta responde la pregunta: *"¿Cuál es nuestro nivel actual de madurez, qué riesgos tenemos sin mitigar, y cuál es el ROI de nuestra inversión en seguridad?"*

1. FUNDAMENTOS TEÓRICOS

1.1 Modelos de Madurez: CMM a la Ciberseguridad

Origen: Capability Maturity Model (CMM), desarrollado por SEI (Carnegie Mellon) para calidad software.

Escala CMM 5 niveles:

- **L1 Inicial:** Procesos impredecibles, caóticos (enfoque ad hoc)
- **L2 Repetible:** Procesos básicos establecidos, resultados consistentes
- **L3 Definido:** Procesos documentados, seguidos consistentemente
- **L4 Gestionado:** Procesos medidos y controlados, optimización continua
- **L5 Optimizado:** Mejora continua enfocada, predicción y anticipación

Aplicación a ciberseguridad: Evaluar madurez NO como sí/no, sino como evolución continua de capacidades.

Analogía: Una empresa L2 tiene política seguridad (no es L1), pero NO es tan avanzada como empresa L4 que mide ROI seguridad automáticamente.

1.2 MAGERIT v3: La Metodología Nacional Española

¿Qué es? Metodología española oficial de Análisis y Gestión de Riesgos en Sistemas de Información, publicada por CCN-CERT.

Estructura: Método de Análisis de Riesgos (MAR) en 4 tareas:

1. MAR.1 Caracterización de Activos
2. Identificar: información, servicios, hardware, software, personal, instalaciones
3. Valorar: impacto por dimensión (Confidencialidad, Integridad, Disponibilidad, Autenticidad, Trazabilidad)
4. Mapear dependencias entre activos
5. MAR.2 Caracterización de Amenazas
6. Identificar amenazas relevantes por activo
7. Estimar frecuencia (ARO - Annual Rate of Occurrence)
8. Calcular potencial degradación (% pérdida valor)
9. MAR.3 Caracterización de Salvaguardas
10. Inventariar controles implementados
11. Evaluar eficacia (L0-L5)
12. Identificar insuficiencias (gaps)
13. MAR.4 Estimación de Riesgo Residual
14. Calcular riesgo residual (frecuencia $\times$ impacto $\times$ (1 - eficacia salvaguarda))
15. Análisis acumulado cascadas
16. Decisiones de tratamiento (mitigar, transferir, compartir, aceptar)

Mapear dependencias entre activos

MAR.2 Caracterización de Amenazas

Calcular potencial degradación (% pérdida valor)

MAR.3 Caracterización de Salvaguardas

Identificar insuficiencias (gaps)

MAR.4 Estimación de Riesgo Residual

Valor: Enfoque estructurado, proporcionalidad (adaptable L0-L5), outputs estandarizados (informes, declaraciones aplicabilidad).

Limitación: No cuantifica en € impacto financiero (por eso se complementa con FAIR/ALE).

1.3 NIST CSF 2.0: Marco de Funciones Empresariales

¿Qué es? Marco flexible de ciberseguridad de NIST (USA), adoptado internacionalmente (incluido por ENS español).

Estructura: 6 funciones (antes 5):

- **Govern (GO):** Estrategia, riesgos, cumplimiento, recursos
- **Identify (ID):** Entender activos, riesgos, contexto
- **Protect (PR):** Salvaguardas (acceso, encriptación, formación)
- **Detect (DE):** Monitorización, detección anomalías
- **Respond (RS):** Procedimientos incidentes, análisis, remediación
- **Recover (RC):** Planes recuperación, lecciones aprendidas

Madurez: Niveles 1-4 por función (Partial – Managed – Adaptive)

Valor: Orientación a negocio, flexibilidad sectorial, internacional.

Aplicación española: NIST se alinea con ENS y es referencia válida para auditoría NIS2.

1.4 ENS (Esquema Nacional de Seguridad): Marco Nacional

¿Qué es? Normativa española (RD 311/2022) que operacionaliza MAGERIT mediante requisitos y medidas de seguridad proporcionales.

22 Requisitos mínimos: Gobernanza, análisis riesgos, medidas, auditoría, incidentes, etc.

Medidas de Seguridad (Anexo II):

- **Marco Organizativo:** Políticas, roles, responsabilidades
- **Marco Operacional:** Procedimientos, procesos
- **Marco de Protección:** Técnicas (cifrado, autenticación, firewalls)

Categorización:

- BÁSICA (bajo impacto)
- MEDIA (moderado)
- ALTA (infraestructura crítica)

Cada categoría con medidas proporcionales (L2, L3, L4 madurez mínima).

Mandatorio para: Administración pública, servicios esenciales (energía, telecom, etc.)

1.5 NIS2: Regulación Europea de Ciberseguridad

¿Qué es? Directiva UE 2022/2555 (en vigor enero 2023) que obliga ciberseguridad a operadores críticos y entidades importantes.

Aplicación en España: Ley de Trasposición en aprobación (enero 2026). Plazo original octubre 2024 incumplido.

Entidades obligadas:

- **Esenciales:** >250 empl. + balance €43M + volumen €50M + sectores Anexo I (energía, telecom, finanzas, transporte, salud, agua, TIC, admin. pública)
- **Importantes:** Sectores Anexo II (postal, químico, alimentario, etc.)

Requisitos clave:

- Análisis riesgos formal
- Plan continuidad negocio (RTO, RPO)
- Cadena suministro segura
- Criptografía fuerte
- Gestión incidentes (notificación <72h autoridades si impacto significativo)
- Formación empleados

Sanciones:

- Esenciales: €10M o 2% volumen negocios (máximo)
- Importantes: €7M o 1,4% volumen negocios

1.6 ISO 27001: Estándar Internacional de SGSI

¿Qué es? Norma internacional que define Sistema de Gestión de Seguridad de la Información (SGSI) certificable.

Estructura: 14 secciones, 93 controles en 4 anexos principales:

- Gobernanza y gestión riesgos
- Identificación y análisis activos
- Acceso y autenticación
- Criptografía
- Vendedores y proveedores
- Gestión incidentes
- Auditoría y mejora continua

Valor: Certificable (empresas auditadas externamente), reconocida internacionalmente.

Aplicación en España: Ampliamente adoptada como base cumplimiento NIS2 y ENS.

2. INDICADORES Y MÉTRICAS: CONECTANDO TEORÍA A PRÁCTICA

2.1 GQM: Goal-Question-Metric (Enfoque de Medición)

Metodología: Desarrollada por David Basili (U. Maryland) para especificar métricas de software.

Estructura piramidal:

GOAL (Objetivo estratégico)



QUESTIONS (Preguntas específicas, medibles)



METRICS (Datos cuantitativos)

Ejemplo en ciberseguridad:

GOAL: Reducir riesgo de robo de datos (MAR.4)



QUESTION: ¿Cuántos sistemas críticos CARECEN de MFA?



METRIC: % sistemas sin MFA = 25%

Aplicación: La encuesta estructura preguntas GQM dentro de cada bloque para conectar objetivos (reducir riesgo) → preguntas operacionales → métricas cuantificadas.

2.2 FAIR: Factor Analysis of Information Risk

¿Qué es? Modelo de cuantificación financiera de riesgo cibernético.

Fórmula base:

$ALE \text{ (Annualized Loss Exposure)} = LEF \times LM$

Donde:

- LEF = Loss Event Frequency = $TEF \times (1 - \text{Control Strength})$
- LM = Loss Magnitude = Primary Loss + Secondary Loss

Componentes:

- **TEF (Threat Event Frequency):** ¿Con qué frecuencia ataca un adversario? (histórico + benchmarking)
- **Control Strength (%):** ¿Eficacia de nuestra defensa? (0-100%, mapeado a CMM L0-L5)
- **Primary Loss (€):** Costo directo (data cleanup, notificación, IT downtime)
- **Secondary Loss (€):** Regulación (multas GDPR 4%), litigio (demandas clientes), reputación (pérdida ingresos)

Ejemplo:

Escenario: Ransomware ataque servidores críticos

- TEF: 0,5 eventos/año (1 cada 2 años histórico)
- Sin control (backup débil): $LEF = 0,5 \times 1,0 = 0,5/\text{año}$
- Con control (backup aislado + testing): $LEF = 0,5 \times 0,1 = 0,05/\text{año}$
- Primary Loss: €50K (recovery, forensics)
- Secondary Loss: €100K (regulación) + €150K (reputación) = €250K
- Total LM: €300K
- ALE sin control: $0,5 \times 300K = €150K/\text{año}$
- ALE con control: $0,05 \times 300K = €15K/\text{año}$
- ROI: $(€150K - €15K - €20K \text{ implementación}) / €20K = 575\%$ (excelente)

Valor: Comunicar riesgo en lenguaje ejecutivo (€), no técnico (CVE, CVSS).

2.3 46 Métricas INCIBE de Ciberresiliencia

¿Qué son? Marco de indicadores para operadores infraestructuras críticas españoles, publicado por INCIBE-CERT.

9 Dominios funcionales:

1. **Gobernanza:** Políticas, responsabilidades, presupuesto
2. **Identificación:** Inventario activos, dependencias
3. **Protección:** Salvaguardas implementadas, eficacia
4. **Detección:** SIEM, monitorización, alertas
5. **Respuesta:** Plan incidentes, SLA respuesta
6. **Recuperación:** Backups, RTO/RPO, drills
7. **Análisis:** Post-mortem, lecciones aprendidas
8. **Mejora:** Evolución documentada, PDCA
9. **Tecnología:** Arquitectura resiliente, redundancia

46 preguntas específicas que permiten autoevaluación estandarizada de ciberresiliencia.

Aplicación: Encuesta integra estas 46 métricas distribuidas en bloques MAGERIT/NIST, permitiendo benchmark con operadores críticos españoles.

3. CONEXIÓN ENTRE ENCUESTA Y ESTÁNDARES

3.1 Mapeo Encuesta ↔ Frameworks

Sección Encuesta	MAGERIT MAR	NIST CSF	ENS	NIS2	ISO 27001
1. Gobernanza	MAR.1 inicio	GO + ID	Req 1-3	Art 17 (Gobernanza)	A.5 (Org.)
2. Riesgos MAR	MAR.1-4 completo	ID, PR	Req 4-6	Art 21 (Análisis)	A.12 (Gestión)
3. Métricas	MAR.4 outputs	GO + medición	Op.mon.2	Req 22 (Medidas)	A.18 (Métricas)
4. Vulnerabilidades	MAR.2 threat	PR + DE	Mp (Protección)	Art 21 (Medidas)	A.14 (Auditoría)
5. SIEM	MAR.4 monitoreo	DE + RS	Op.mon + Op.exp	Art 21 (Detección)	A.16 (Incidentes)
6. Capacitación	MAR.3 salvaguarda	PR + GO	Org.2	Art 21 (Formación)	A.6 (Personas)
7. Resiliencia	MAR.4 recuperación	RC	Op.exp.6-8	Art 21 (Continuidad)	A.17 (Continuidad)
8. Cumplimiento	Todo (proporcionalidad)	Todo	Todo	Todo	Todo
9. Incidentes	MAR.4 tratamiento	RS	Op.exp.7	Art 21 (Notificación)	A.16 (Incidentes)
10. Madurez	Auto-assessment	Niveles madurez	CMM L0-L5	Conformidad integral	SGSI integrado integral

Interpretación: Cada pregunta de la encuesta está mapeada a requisito específico. Respuesta "L1" en pregunta = potencial no-conformidad con requisito.

3.2 Proporcionalidad: MAGERIT L0-L5 → Categorías ENS

Principio MAGERIT: Medidas proporcionales al riesgo identificado.

Mapeo automático:

Impacto Activo (ALTO) + Frecuencia Amenaza (MEDIA)

- Riesgo residual ALTO
- Categoría ALTA
- Medidas L4 mínimo (casi todos controles)

Impacto Activo (BAJO) + Frecuencia Amenaza (BAJA)

- Riesgo residual BAJO
- Categoría BÁSICA
- Medidas L2 mínimo (controles básicos)

Valor: Evita "one-size-fits-all". PyME con activos no-críticos puede ser L2-3; Banco con datos sensibles debe ser L4-5.

4. CASOS DE USO: INTERPRETACIÓN DE RESULTADOS

4.1 Caso 1: Empresa Asimétrica (Gobernanza fuerte, Operaciones débiles)

Resultado típico: IGM 60%, pero Bloque 1 (Gobernanza) 80%, Bloque 5 (SIEM) 35%

Interpretación:

- "Tenemos políticas buenas, Junta entiende ciberseguridad (L4)"
- "Pero operaciones no las ejecutan (L2-3 en detección/respuesta)"
- "Brecha de ejecución: plan bueno, implementación fallida"

Recomendación: Priorizar automatización operacional (SIEM, alerting, playbooks) antes de crear nuevas políticas.

ROI alto: Inversión €50K SIEM reduce ALE €200K/año → Payback 3 meses.

4.2 Caso 2: Startup / PyME (Todo L1-L2, crecimiento rápido)

Resultado típico: IGM 28%, L1 en todos bloques, sin auditoría

Interpretación:

- "Seguridad es 'mañana' (ad hoc hoy)"
- "No hay documentación, roles sin asignación formal"
- "Riesgo regulatorio CRÍTICO si operador NIS2"

Recomendación:

1. Audit seguridad: Identificar activos críticos (MAR.1)
2. Policy básica: Gobernanza L2 (mínimo)
3. Formación: Concienciación empleados L2
4. Monitorización: SIEM básico (open-source)
5. Plan incidentes: Procedimiento L2 (documento simple)

Timeline: 6 meses a L3 = €50-100K inversión.

4.3 Caso 3: Banco / Operador Crítico (Aspirar a L4-5)

Resultado típico: IGM 72%, L4 en mayoría bloques, L3 en Respuesta/Recuperación

Interpretación:

- "Baseline de gobernanza y protección sólido"
- "Debilidad específica: Tiempo respuesta incidentes (>4h)"
- "Incumplimiento NIS2: Coordinación 72h autoridades no sistematizada"

Recomendación:

1. Automatización SOAR: Playbooks respuesta automáticos (L4)

2. SOC 24/7: Staffing + threat hunting continuo
3. Simulacros: Ejercicios mensuales RTO/RPO
4. Coordinación: Protocolo notificación CCN-CERT <24h

ROI: Reducción MTTR (Mean Time to Recover) 4h → 1h = Ahorro reputación incalculable.

5. LIMITACIONES Y EXCEPCIONES

5.1 "Nuestra industria es diferente"

Ejemplo: Hospital (crítico 24/7) vs. Constructora (oficina 9-17)

Realidad: Encuesta es agnóstica, pero interpretación de "madurez aceptable" varía:

- Hospital: L4+ en Respuesta/Recuperación (no negociable)
- Constructora: L3 suficiente si riesgo bajo

Solución: Ajustar "target madurez" por sector + tamaño + criticidad.

5.2 "Somos startup, no podemos invertir mucho"

Realidad: Ciberseguridad NO es lujo, es requisito regulatorio (RGPD, NIS2 si aplica).

Solución práctica L0-Cost:

- Políticas: Documentar (0 €, 10h)
- Formación: INCIBE (cursos online gratuitos)
- Monitoreo: ELK Stack (open-source)
- Backups: Script automático (0 €, 5h)
- Total: €0, ~40 horas → L2-L3

5.3 "Algunos datos los terceriza mos"

Realidad: Terceros no eliminan responsabilidad. NIS2 obliga auditoría proveedores.

Solución: Añadir preguntas a terceros:

- ¿ISO 27001 certificado? (sí/no)
- ¿Auditoría anual? (sí/no)
- ¿SLA incidentes? (sí/no)
- Restar puntuación si tercero es L1-L2 en áreas críticas.

6. PRÓXIMOS PASOS: DE LA TEORÍA A LA ACCIÓN

Esta encuesta NO es un fin en sí, sino punto de partida:

17. Diagnóstico (hoy): Encuesta completa, análisis IGM
18. Brecha → Priorización (1 semana): Top 10 mejoras, presupuesto
19. Ejecución (6-24 meses): Plan de acción por hitos
20. Monitoreo (continuo): Mini-assessments trimestrales
21. Re-evaluación (anual): Encuesta completa, tracking progreso

Objetivo final: Alcanzar L4 (Gestionado) o L5 (Optimizado) sostenible, alineado con regulación y riesgo organizacional.

© 2026 Narrativa Explicativa Kit MAGERIT-NIS2-ENS | Consorcio Ciberseguridad

Referencia teórica para entendimiento frameworks y métrica.